# Product Security Across the Lifecycle

A device's security isn't finished when it ships. It spans the **total product lifecycle (TPLC)**, from the first design idea until the last unit leaves service: dozens of releases in a few years for an app like DermaLens, about 15 years for a robot like OrionArm.

### PREMARKET
design, build, verify

- Security plan
- Threat modeling
- Security risk assessment
- Architecture views
- Requirements and controls
- Testing and pen testing
- SBOM
- Traceability

KEY DELIVERABLES
**Threat model, risk file**
**Test reports and SBOM**
**Traceability matrix**

### RELEASE
submit and launch

- Submission content
- Security labeling
- MDS2 form
- Customer documents
- SBOM for customers
- Monitoring starts

KEY DELIVERABLES
**The submission**
**Labeling and MDS2**
**Customer SBOM**

### POSTMARKET
monitor and maintain

- Vulnerability monitoring
- CVD and a PSIRT
- Assess risk to patients
- Patches and updates
- Customer communication
- Regulator reporting
- ISAO information sharing
- Incident response

KEY DELIVERABLES
**Validated updates**
**Customer advisories**
**Regulator reports**

### END OF SUPPORT
plan the exit

- Announce dates early
- Final updates
- Compensating controls
- Customer guidance
- Plan replacement
- Secure decommissioning
- Shared responsibility

KEY DELIVERABLES
**End-of-support notice**
**Final updates**
**Data-wiping instructions**

**In every phase: security risk management, the SBOM and the design history stay current**

**Postmarket findings feed the next design change and the next release**

**The phases are linked.** A device never designed for updates can't be patched; a team that never recorded its software can't tell whether a new vulnerability affects it.

**The lifecycle is a loop.** A postmarket fix or feature is a design change: it goes back through threat modeling, testing and documentation.

## Premarket deliverables checklist

Premarket work produces a product secure enough for its intended use, and the evidence that shows it to regulators, hospital customers and future colleagues. Produce the evidence during design: reconstructing it later is slow and usually reveals gaps.

- [ ] **Security plan:** who does which security activities, when, and what they deliver. CardiaPace schedules threat modeling before design freeze, not after.
- [ ] **Threat model and security risk assessment:** what could go wrong, how exploitable it is, how bad for patients, what to do. FlowGuard: "What if someone replaces the drug library?"
- [ ] **Architecture views:** components, connections, data flows and trust boundaries (where control changes hands). DermaLens: app, cloud, model, dashboard, and who controls each.
- [ ] **Security requirements and controls:** testable requirements that answer the significant threats. OrionArm remote service needs strong login and hospital approval per session.
- [ ] **Security testing:** evidence the controls work, plus penetration testing (skilled testers trying to break in). An independent pen test of the CardiaPace home transmitter.
- [ ] **SBOM:** software components with versions and whether each is still supported by its supplier. DermaLens records every open-source library in app and cloud.
- [ ] **Labeling and customer documents:** secure setup, network needs, how updates arrive, support period, and the **MDS2** form hospitals use to compare devices. Hospital IT reads FlowGuard's MDS2.
- [ ] **Traceability:** each threat linked to its control, the test that verifies it, and the residual risk; gaps are often a reviewer's first question.

### The US submission for a cyber device

The law requires a plan to monitor and address postmarket vulnerabilities (including coordinated vulnerability disclosure), processes that give reasonable assurance the device is secure, and an SBOM. FDA's guidance adds the SPDF, threat model and risk assessment, architecture views, controls, testing evidence, labeling and a cybersecurity management plan. Other regulators ask for similar material. Clearance starts the longest phase; it isn't the finish line.

## Postmarket: watch, assess, fix and tell

A product's security changes after release even if its code doesn't. Findings arrive from **vulnerability monitoring** (checking the SBOM against vulnerability databases and supplier advisories), from researchers through **coordinated vulnerability disclosure (CVD)**, and from complaints and service calls. Many organizations route them all to a **product security incident response team (PSIRT)**.

### Handling a vulnerability report

Example: a researcher reports that FlowGuard pumps accept unsigned drug-library files.

1. **Acknowledge** the report to the researcher and open a case.
2. **Triage:** reproduce it; find affected versions and components.
3. **Assess** exploitability and patient harm: controlled or uncontrolled?
4. **Develop and validate a fix**, plus interim measures if needed.
5. **Coordinate disclosure:** agree timing with the researcher, publish customer guidance, report to regulators.
6. **Release the update**, help hospitals deploy it, track patched units.
7. **Close the loop:** update the threat model, SBOM and design practices.

Steps often overlap: with uncontrolled risk, interim guidance may go out before the full fix, and regulator reporting runs alongside.

### Controlled or uncontrolled risk?

Not every vulnerability is an emergency. FDA's postmarket guidance sorts assessed risk into two kinds:

**Controlled**

Remaining risk of patient harm is **acceptable** with the controls in place.

Record the assessment; fix it in a **routine update**. Generally not reportable to FDA.

**Uncontrolled**

Remaining risk of patient harm is **unacceptable**.

**Prompt remediation**, faster and wider customer communication, often interim measures; generally reportable.

FDA eases reporting for an uncontrolled risk if there are no known serious adverse events or deaths, customers are told within 30 days, it is fixed or mitigated within 60 days, and the manufacturer is in an ISAO (information sharing and analysis organization) such as Health-ISAC. Regulatory decides what is reportable where.

**Patient safety lens.** A patch is a clinical decision too: updating a pump mid-infusion, or an implant in a fragile patient, carries its own risk. Interim measures, such as restricting a network connection, must not create a new hazard.

## How fast can a fix reach patients?

| DERMALENS APP | FLOWGUARD PUMPS | ORIONARM ROBOT | CARDIAPACE IMPLANT SYSTEM |
|---|---|---|---|
| An app update can reach users within days. | Scheduled with each hospital's biomedical engineers. | Planned around surgery lists. | The transmitter updates itself; the implant usually needs a clinic visit. |

Every update is a device change, verified and validated first. US law expects updates on a regular cycle for known unacceptable vulnerabilities, and out of cycle, as soon as possible, for critical ones.

## End of support and legacy devices

**End of life:** the manufacturer stops selling a product. **End of support:** it stops providing service and support, including security updates. A **legacy device** can no longer be reasonably protected against current threats, yet is often still in clinical use. OrionArm's commercial operating system will typically get security updates for far fewer years than its 15-year service life.

DESIGN
**Plan the exit early**

Choose long-supported components, make the operating system upgradeable, record support dates in the SBOM.

IN SERVICE
**Tell customers in time**

Announce dates early, offer upgrades, advise on **compensating controls** such as network separation.

RETIREMENT
**Leave nothing behind**

Give final updates and instructions for wiping patient data, credentials and network settings before disposal or resale.

**Shared responsibility.** Manufacturers communicate support timelines and options clearly; hospitals keep device inventories, apply compensating controls and budget for replacements. A hospital can't patch an operating system the manufacturer hasn't validated, and a manufacturer can't segment a hospital's network. The goal is to keep the remaining risk visible and controlled.

Regulatory points current as of October 2026. All four devices are fictional. Training material, not legal or regulatory advice.